

Piwigo

目标10.97.13.176

```
Piwigo [正在运行] - Oracle VM VirtualBox
管理 控制 视图 热键 设备 帮助

Welcome to Alpine Linux 6.12.74-0-lts on an x86_64 (/dev/tty1)
===== Made By =====

      d8888b.      888      888
      8P Y88b      888      888
      8b.          888      888
      Y888b.      888 888 88888b. 888 8888b. 888d888 .d88b. .d88b.
      "Y88b. 888 888 888 "88b 888 "88b 888P" d88P"88b d8P Y8b
      "888 888 888 888 888 888 .d888888 888 888 888 88888888
      8b d88P Y88b 888 888 d88P 888 888 888 Y88b 888 Y8b.
      Y8888P" "Y88888 88888P" 888 "Y888888 888 "Y88888 "Y8888
                                   888
                                   Y8b d88P
                                   "Y88P"

                                           @maze-sec.com
===== Happy Hacking! =====

hostname : Piwigo
IP       : 10.97.13.176
Piwigo login: _
```

常规扫描

```

< Anonymous on Sunday at 7:40 PM
> { C: = Penetration = ScanTools = Nmap } * nmap.exe -sS -sV -sC -O -p- -T4 -n -oA fullscan 10.97.13.176
Starting Nmap 7.97 ( https://nmap.org ) at 2026-03-22 19:41 +0800
Nmap scan report for 10.97.13.176
Host is up (0.0013s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.66 ((Unix))
|_ http-server-header: Apache/2.4.66 (Unix)
|_ http-title: It works! Apache httpd
|_ http-methods:
|_ Potentially risky methods: TRACE
MAC Address: 08:00:27:21:8C:D4 (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 33.90 seconds

```

```

< kali on Sunday at 7:41 PM
> { home = tools = feroxbuster } * ./feroxbuster -u http://10.97.13.176/ --depth=2 -x php,html,txt,zip,bak
0s MEM: 10.44% (0/3GB)

FERREX OXIDE
by Ben "ept" Risher ver: 2.13.1

Target Url      http://10.97.13.176/
In-Scope Url    10.97.13.176
Threads         50
Wordlist         /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
Status Codes     All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Extract Links    true
Extensions      [php, html, txt, zip, bak]
HTTP methods     [GET]
Recursion Depth 2

Press [ENTER] to use the Scan Management Menu"

403 GET 9l 29w 315c Auto-filtering found 404-like response and created new filter; toggle off with --dont-f
ilter
404 GET 9l 32w 312c Auto-filtering found 404-like response and created new filter; toggle off with --dont-f
ilter
200 GET 10l 23w 219c http://10.97.13.176/
200 GET 10l 23w 219c http://10.97.13.176/index.html
[#####] - 30s 180000/180000 0s found:2 errors:0
[#####] - 30s 180000/180000 6100/s http://10.97.13.176/

```

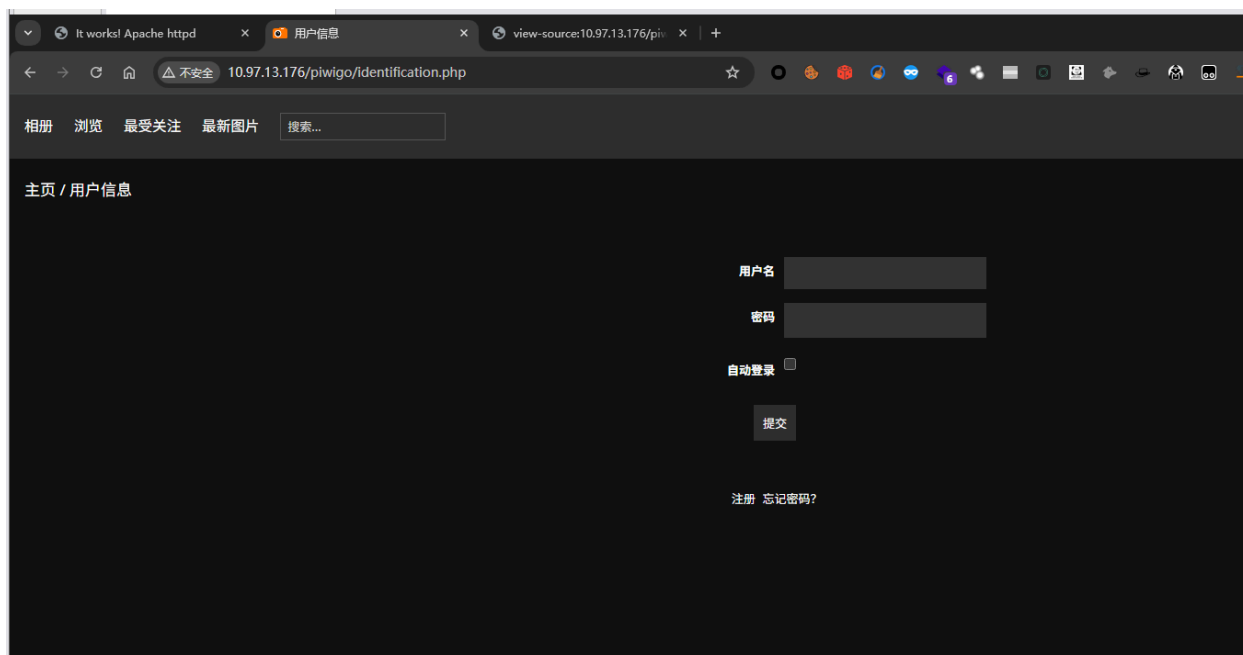
源码发现提示，还有暴力破解

```

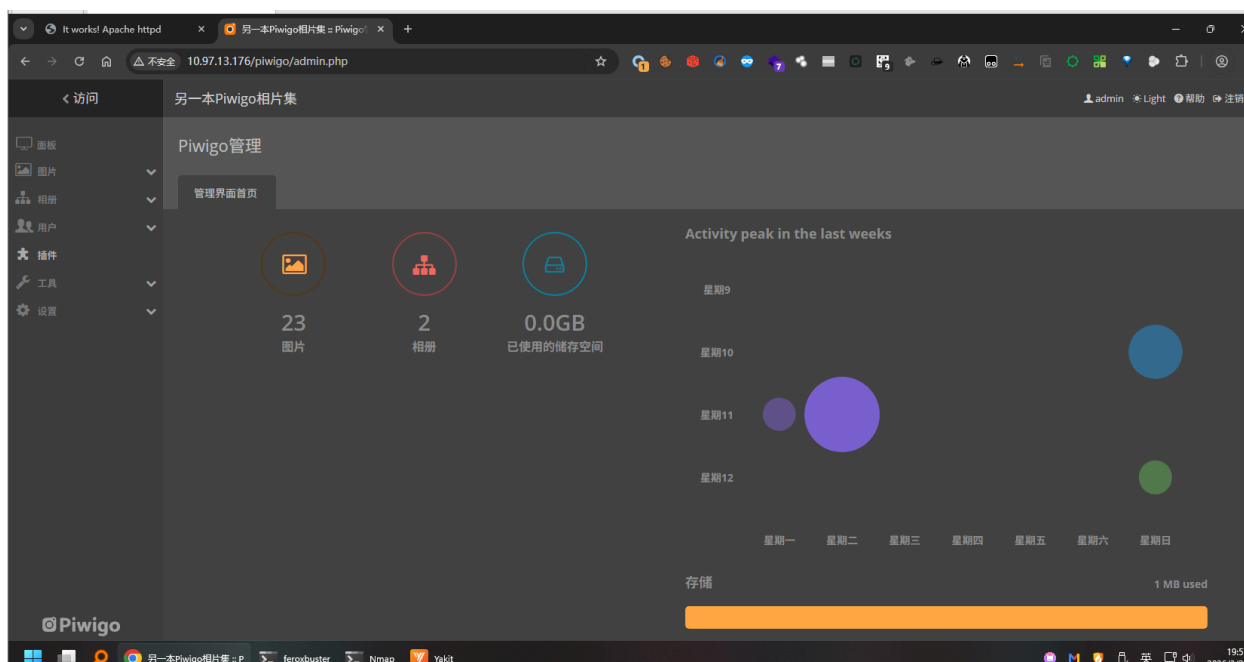
换行
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html>
<head>
<title>It works! Apache httpd</title>
</head>
<body>
<p>It works!</p>
<!-- /piwigo bruteforce -->
</body>
</html>

```

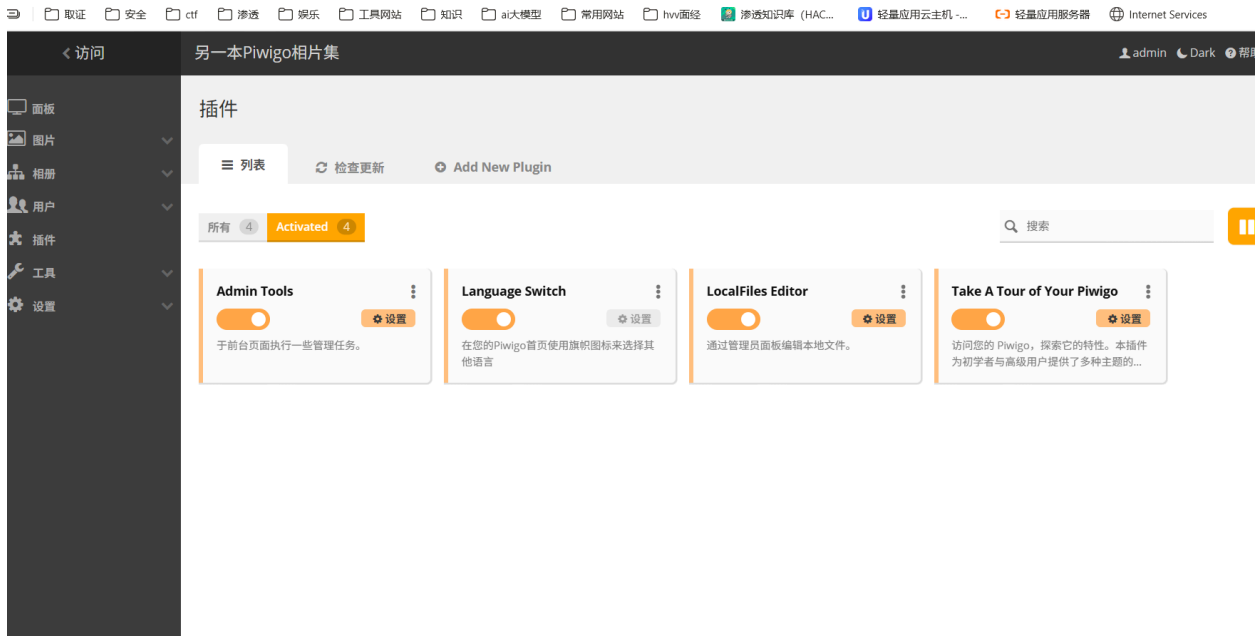
爆破出来admin密码是killer



进入管理面板

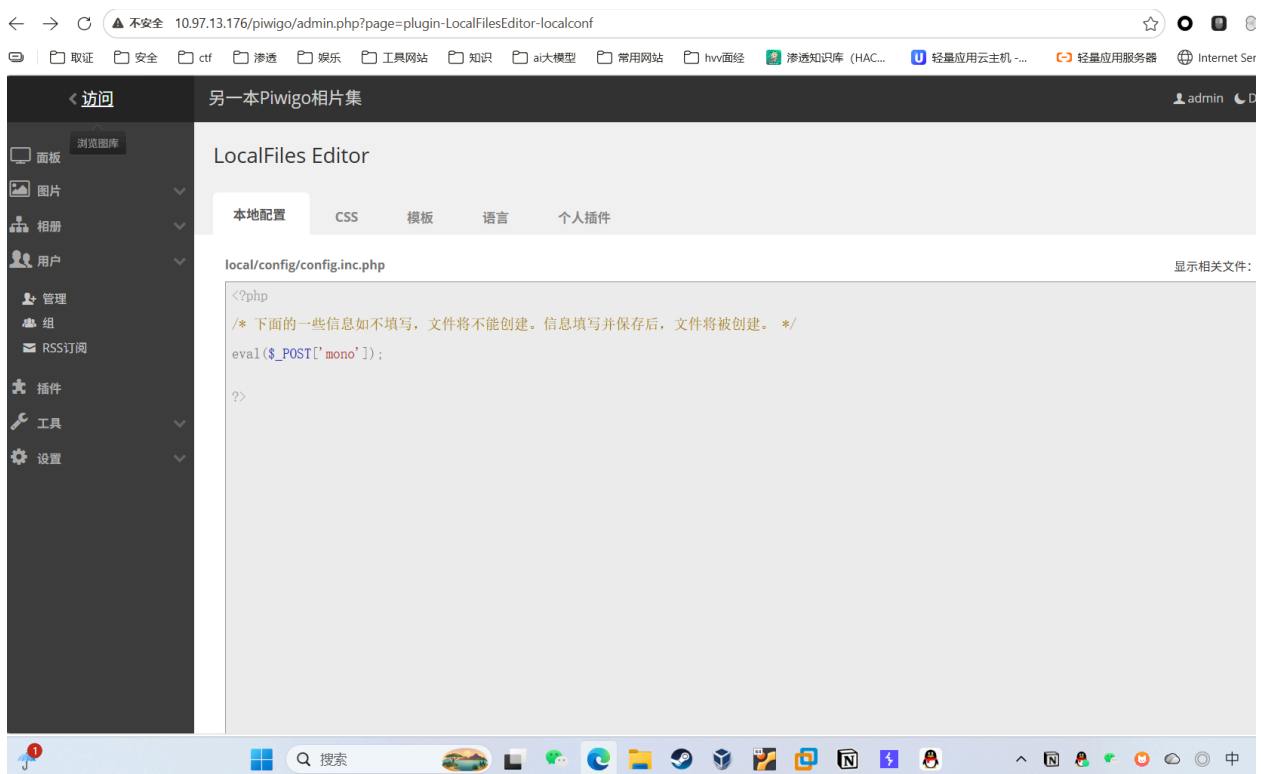


有个插件locate files editor

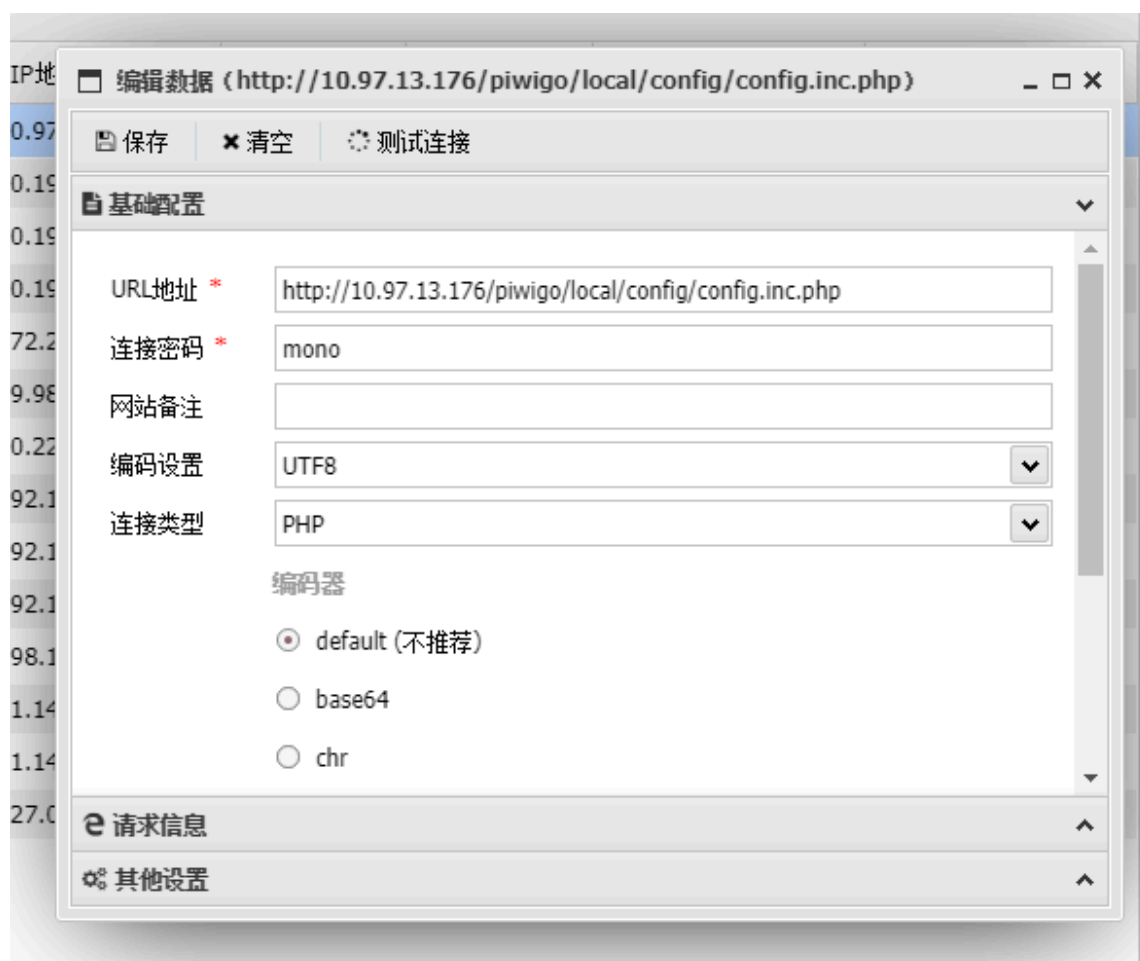


查了一下这样可以访问插件

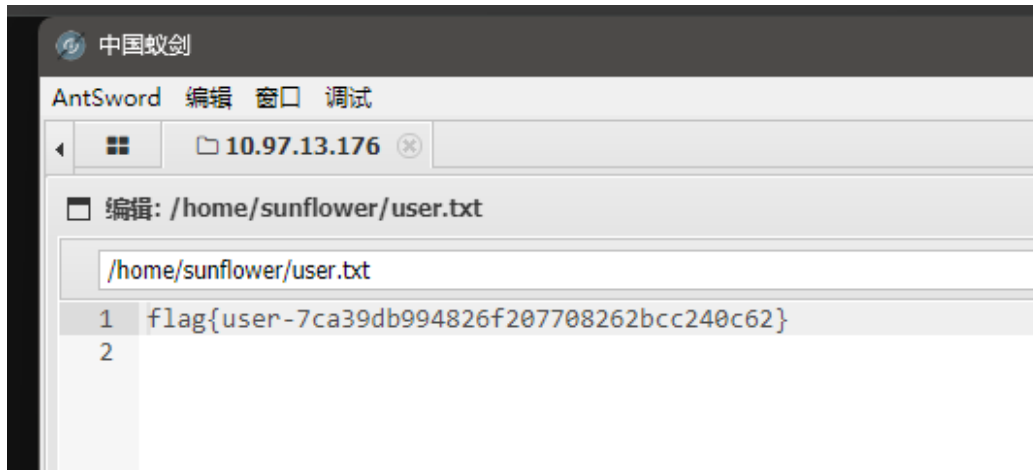
<http://10.97.13.176/piwigo/admin.php?page=plugin-LocalFilesEditor-localconf>



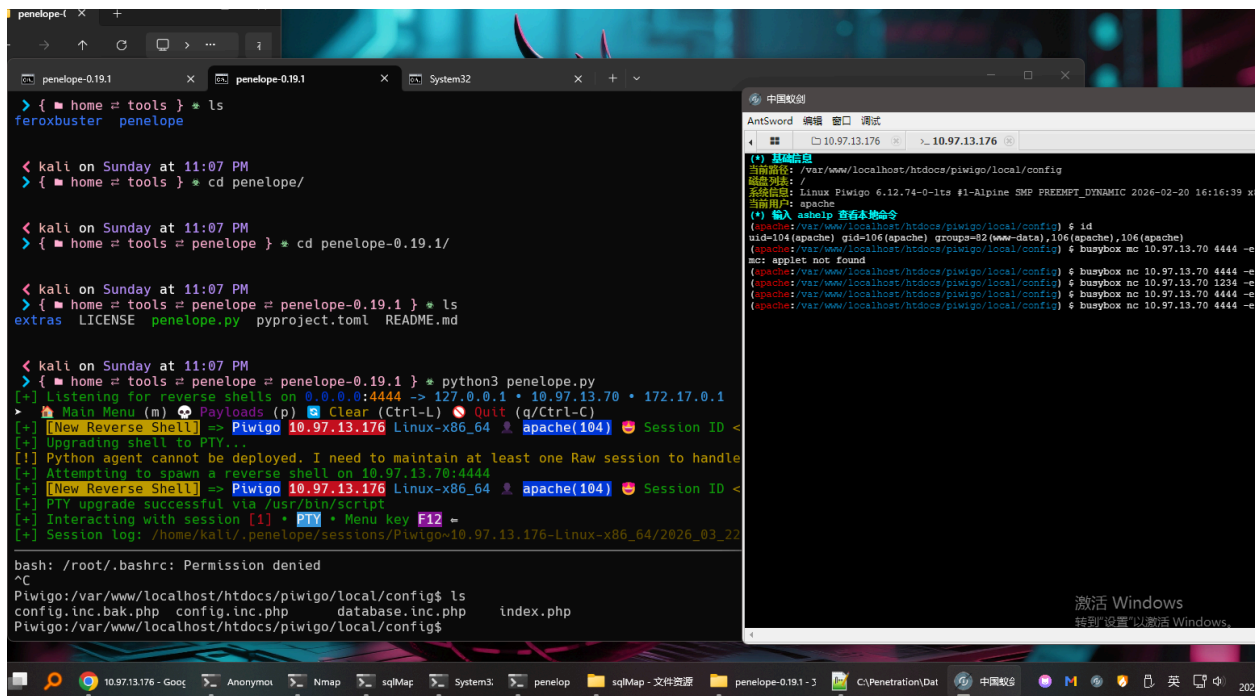
写入蚁剑木马并连接



得到第一个flag: flag{user-7ca39db994826f207708262bcc240c62}



反弹shell



运行linpeas，发现一个奇怪的数据库文件

```

odbc.allow_persistent = On
mysqli.allow_persistent = On
pgsql.allow_persistent = On

===== Analyzing PAM Auth Files (limit 70)
drwxr-xr-x 2 root root 4096 Jan 29 20:20 /etc/pam.d

===== Analyzing Http conf Files (limit 70)
-rw-r--r-- 1 root root 17884 Dec 8 01:16 /etc/apache2/httpd.conf

===== Analyzing Github Files (limit 70)
drwxr-xr-x 3 root root 4096 Mar 8 23:42 /var/www/localhost/htdocs/piwigo/include/smarty/

===== Analyzing KeePass Files (limit 70)
-rw-r--r-- 1 root root 1461 Mar 9 00:09 /opt/my_database.kdbx

===== Analyzing Interesting logs Files (limit 70)
-rw-r--r-- 1 root apache 20214708 Mar 22 23:22 /var/log/apache2/access.log
-rw-r--r-- 1 root apache 5355691 Mar 22 22:57 /var/log/apache2/error.log

===== Analyzing Windows Files (limit 70)

```

网上找了一下是一个加密文件，可以被爆破
提取并爆破hash，密码monkey，keepass打开

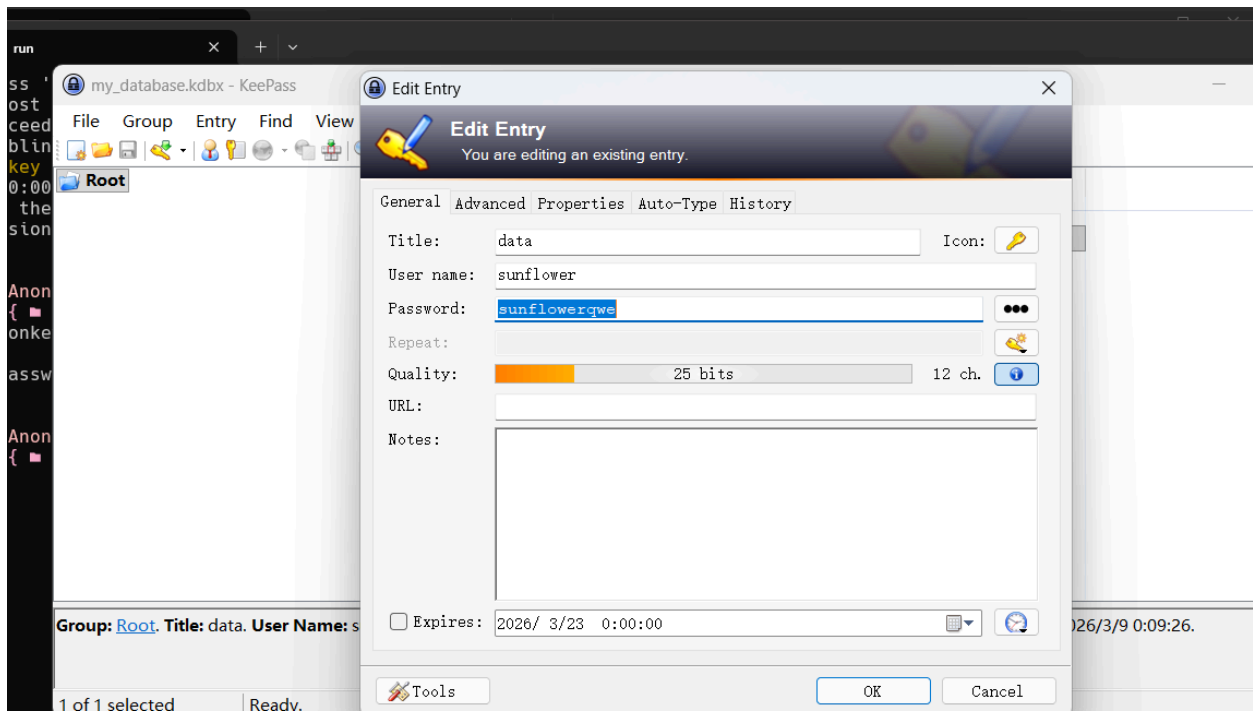
```

< Anonymous on Monday at 12:11 AM 0.17s MEM: 68% (5/7GB)
> { ■ home = Desktop = tools = JtR = run } * keepass2john.exe C:\Users\Anonymous\Desktop\my_database.kdbx
my_database:$keepass$*4*14*ef636ddf*67108864*19*2*b52178a734d0b577423679d02ab37dd17cb6781861d216c7d32d52c354ab2123*7839e86543e0449
b3d6cc46b95b4bbab7d519c7eb01d9cf59d64d82f6ab1a15f*03d9a29a67fb4bb500000400021000000031c1f2e6bf714350be5805216afc5aff0304000000100
0000420000000b52178a734d0b577423679d02ab37dd17cb6781861d216c7d32d52c354ab2123071000000090ba3750281556cb96fa4c43545a9760b8b000000
001420500000024555494410000000ef636ddf8c29444b91f7a9a403e30a0c05010000004908000000e00000000000005010000004d08000000000000400
0000004010000005004000000020000004201000000053200000007839e86543e0449b3d6cc46b95b4bbab7d519c7eb01d9cf59d64d82f6ab1a15f040100000056
b40000001300000000000400000000d0a0d0a*cec0713f583979307e358e7cfd1fa7c80c4bb2c61a7284d83f70de0228d03d29

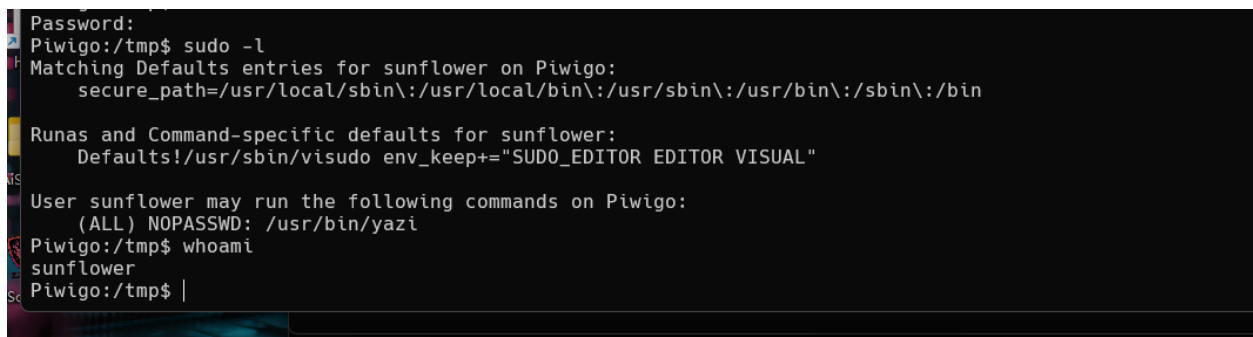
< Anonymous on Monday at 12:13 AM 0.101s MEM: 67% (5/7GB)
> { ■ home = Desktop = tools = JtR = run } * john.exe C:\Users\Anonymous\Desktop\hash.txt
KeePass-openc1: Argon2 hash(es) not supported, skipping.
Warning: detected hash type "KeePass", but the string is also recognized as "KeePass-Argon2-openc1"
Use the "--format=KeePass-Argon2-openc1" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (KeePass [AES/Argon2 256/256 AVX2])
Cost 1 (t (rounds)) is 14 for all loaded hashes
Cost 2 (m) is 65536 for all loaded hashes
Cost 3 (p) is 2 for all loaded hashes
Cost 4 (KDF [0=Argon2d 2=Argon2id 3=AES]) is 0 for all loaded hashes
Will run 4 OpenMP threads
Note: Passwords longer than 41 [worst case UTF-8] to 124 [ASCII] rejected
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:password.lst
Enabling duplicate candidate password suppressor
monkey (?)

```

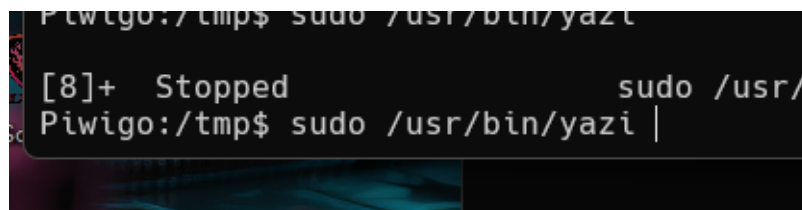
激活 Windows
转到“设置”以激活 Windows。



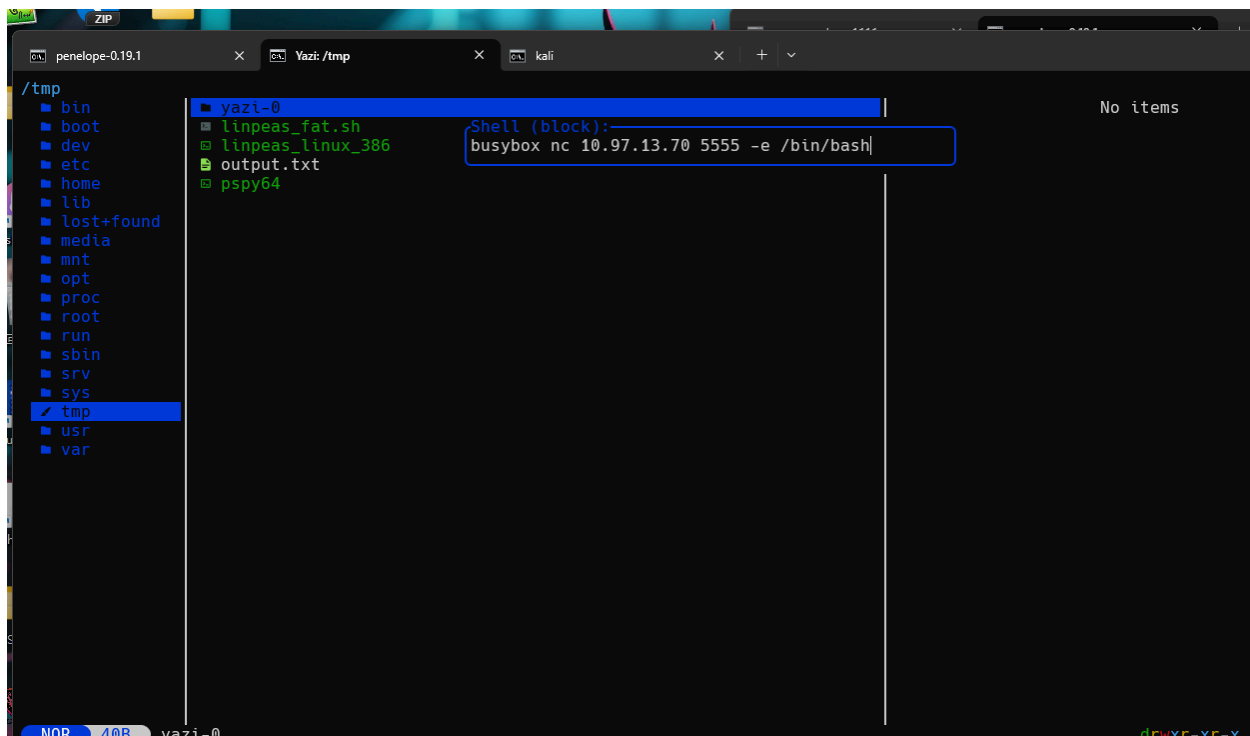
su sunflower sudo -l



直接运行



输入： 在shell里面写nc反弹个shell



得到root权限查看root.txt（之前不小心被我删了...）

```
root@user:~# whoami  
root  
root@user:~#
```